

บทที่ 8

การพัฒนาระบบไฟร์เบรก

8.1 แนวคิด

ไฟร์เบรก (FireBreak) ทำหน้าที่เป็นซีเคียวริตี้เว็บพรีอ็อกซี่ให้กับระบบเพื่อเพิ่มความปลอดภัยให้กับเว็บเซิร์ฟเวอร์ที่อยู่ภายในโซน DMZ และเป็นปราการด่านสุดท้ายที่ผู้บุกรุกจะต้องเจอก่อนที่จะเข้าถึงเว็บเซิร์ฟเวอร์ของเรา โดยในโครงการนี้ได้ใช้ความสามารถของโปรแกรม Squid-cache ในการทำงานเป็นรีเวิร์สเว็บพรีอ็อกซี่ ทำให้เมื่อผู้บุกรุกสร้างการเชื่อมต่อไปยังเว็บเซิร์ฟเวอร์จะต้องผ่านไฟร์เบรกก่อนทุกครั้ง ซึ่งไฟร์เบรกจะมีระบบตรวจจับการบุกรุกอยู่ภายในเพื่อทำการตรวจสอบการเชื่อมต่อที่เข้ามายังไฟร์เบรกว่าเข้าข่ายเป็นผู้บุกรุกหรือไม่ โดยในโครงการนี้ได้ใช้โปรแกรมสนอร์ตอินไลน์ เป็นเครื่องมือในการตรวจสอบ

8.2 ขอบเขตความสามารถ

ไฟร์เบรกสามารถตรวจสอบแพ็คเก็ตที่จะเข้าสู่เว็บเซิร์ฟเวอร์ที่อยู่ข้างในได้ โดยผู้ที่ต้องการติดต่อกับเว็บเซิร์ฟเวอร์จะไม่สามารถติดต่อกับเว็บเซิร์ฟเวอร์ได้โดยตรงแต่ต้องติดต่อผ่านไฟร์เบรกก่อน ดังนั้นจึงไม่สามารถโจมตีเว็บเซิร์ฟเวอร์โดยตรงได้ แต่การโจมตีจะเกิดขึ้นกับตัวเครื่องไฟร์เบรกนี้แทน ซึ่งไฟร์เบรกนี้จะอาศัยโปรแกรม Squid-cache ในการทำหน้าที่เป็นซีเคียวริตี้เว็บพรีอ็อกซี่ให้กับเว็บเซิร์ฟเวอร์ และเนื่องจากทุก ๆ การเชื่อมต่อที่จะติดต่อไปยังเว็บเซิร์ฟเวอร์จะต้องติดต่อผ่านทางไฟร์เบรกนี้ทุกครั้ง ซึ่งภายในไฟร์เบรกจะมีระบบตรวจจับผู้บุกรุกทำงานอยู่ทำให้ทุก ๆ แพ็คเก็ตที่ร้องขอเข้ามาจะต้องผ่านการตรวจสอบโดยโปรแกรมสนอร์ตอินไลน์ เพื่อแยกแยะผู้บุกรุกออกจากผู้ใช้งานจริง และหากการเชื่อมต่อหรือแพ็คเก็ตใด ๆ เข้าข่ายเป็นผู้บุกรุก ระบบไฟร์เบรกจะทำการตัดการเชื่อมต่อนั้นทันทีเพื่อป้องกันการโจมตีหรือการบุกรุกต่างๆ ที่อาจจะเกิดขึ้นได้

เนื่องจากในการบุกรุกทางเว็บแอปพลิเคชันนั้น มีรูปแบบและวิธีการใหม่ ๆ อยู่เสมอทำให้ต้องมีการอัปเดต Signature ของสนอร์ตอินไลน์ อยู่เสมอเพื่อให้สามารถตรวจจับการบุกรุกรูปแบบใหม่ ๆ ได้ ทางผู้พัฒนาจึงได้เพิ่มความสามารถในการอัปเดต Signature ของสนอร์ตอินไลน์ที่ทำงานอยู่ในไฟร์เบรกด้วย

8.3 เทคโนโลยีที่ใช้ในการพัฒนาโปรแกรม

8.3.1 โปรแกรม Squid

สำหรับความสามารถในการทำหน้าที่เป็นรีเวิร์สเว็บพร็อกซี่ของไฟร์เบรกกั้น จะอาศัยโปรแกรม Squid-cache ซึ่งเป็นโปรแกรมแบบเปิดเผยแพร่สโตร์โค้ด สำหรับใช้งานเป็นเว็บพร็อกซี่ ซึ่งสามารถนำมาประยุกต์ใช้เป็นรีเวิร์สเว็บพร็อกซี่สำหรับเว็บเซิร์ฟเวอร์ในโครงงานนี้ได้ โดยสามารถดาวน์โหลดซอร์สโค้ดของ Squid-cache ได้ที่เว็บ <http://www.squid-cache.org> ในที่นี้ใช้เวอร์ชัน 2.5

Squid-cache มีลักษณะการตั้งค่าการใช้งานโดยทำการแก้ไขได้ที่ไฟล์ `squid.conf` ซึ่งโดยปรกติจะอยู่ที่ `/etc/squid/squid.conf` ซึ่งเป็นไฟล์สำหรับการตั้งค่าต่าง ๆ ของโปรแกรม squid-cache ซึ่งมีการอธิบายการใช้งานของแต่ละคำสั่งอยู่แล้ว ในโครงงานนี้เพื่อการใช้งานเป็นรีเวิร์สเว็บพร็อกซี่ จึงต้องทำการตั้งค่าในไฟล์ `squid.conf` ดังต่อไปนี้

```

http_port 80
visible_hostname 172.16.144.131
httpd_accel_host 172.16.144.131
httpd_accel_port 80
http_access allow all

```

คำอธิบายในการใช้งานส่วนต่าง ๆ ของไฟล์ `squid.conf`

- `http_port` - ใช้กำหนดพอร์ตที่ใช้ในการรับการติดต่อที่เข้ามายังไฟร์เบรก ซึ่งทำหน้าที่เป็นพร็อกซี่ โดยค่าเริ่มต้นจะมีค่าเป็น 3128 ดังนั้นเพื่อทำหน้าที่เป็นรีเวิร์สเว็บพร็อกซี่จึงต้องกำหนดค่าเป็น 80 ซึ่งเป็นพอร์ตทั่วไปในการใช้งาน HTTP
- `visible_hostname` - ใช้สำหรับระบุโฮสต์ที่เป็นเว็บเซิร์ฟเวอร์เมื่อเกิด `error_message` ในการทำงานของ Squid กรณีที่ไม่สามารถระบุได้ว่าโฮสต์ที่เป็นเว็บเซิร์ฟเวอร์คือเครื่องใด
- `httpd_accel_host` - ใช้สำหรับระบุโฮสต์ที่ทำหน้าที่เป็นเว็บเซิร์ฟเวอร์จริงที่อยู่ข้างหลังไฟร์เบรกเพื่อทำให้มีคุณสมบัติเป็น Transparent Proxy ซึ่งในที่นี้คือโฮสต์ที่มีไอพีแอดเดรสเป็น 172.16.144.131
- `httpd_accel_port` - ใช้ระบุพอร์ตที่ใช้งานของเว็บเซิร์ฟเวอร์จริง ในการทำเป็น Transparent Proxy
- `http_access` - ใช้ระบุสิทธิ์ผู้ที่สามารถใช้งานรีเวิร์สเว็บพร็อกซี่ไฟร์เบรกนี้ได้ โดยค่าเริ่มต้นจะเป็น `deny all` แต่เนื่องจากการใช้งานเป็นรีเวิร์สเว็บพร็อกซี่นี้จะรองรับบริการทั้งจากเครือข่ายภายในและจากอินเทอร์เน็ตซึ่งจะต้องเข้าใช้งานได้หมด จึงต้องเปลี่ยนค่าเป็น `allow all`

8.3.2 โปรแกรม Snort-inline

สำหรับความสามารถตรวจจับผู้บุกรุกที่เข้ามายังไฟร์เบรคจะโปรแกรม Snort-inline โดยใช้ความสามารถในการเป็น Intrusion Prevention System (IPS) ในการตรวจจับแพ็คเก็ตที่เป็นอันตรายต่อเว็บเซิร์ฟเวอร์ของระบบ โดยถ้าไฟร์เบรคพบการเชื่อมต่อหรือแพ็คเก็ตใด ๆ ที่น่าสงสัย และมีพฤติกรรมเข้าข่ายผู้บุกรุก ตรงกับ Signature ของ Snort-inline ไฟร์เบรคจะทำการดรอ๊ปแพ็คเก็ตนั้นทิ้งทันที แล้วทำการส่งล็อกไฟล์ของการบุกรุกนั้น ๆ ไปแสดงผลที่โปรแกรมควบคุม Tartarus Management ต่อไป

ในโครงการนี้ได้ใช้ซอร์สโค้ดของ Snort-inline เวอร์ชัน 2.3.0-RC1 ซึ่งสามารถดาวน์โหลดได้ที่ http://prdownloads.sourceforge.net/snort-inline/snort_inline-2.3.0-RC1.tar.gz?download โดยหลังจากการติดตั้งแล้วให้ทำการแก้ไขไฟล์ snort_inline.conf ซึ่งโดยปกติจะอยู่ที่ /etc/snort_inline/snort_inline.conf โดยแก้ไขข้อความดังต่อไปนี้

```
var RULE_PATH /etc/snort_inline/drop_rules
output alert_full : snort_inline-full
output alert_fast : snort_inline-fast
```

ให้เป็นข้อความดังต่อไปนี้

```
var RULE_PATH /etc/snort_inline/rules
output alert_full : snort_inline-full
output alert_fast : snort_inline-fast
```

8.3.3 โปรแกรม Oinkmaster

สำหรับการอัปเดต Signature หรือกฎของ Snort-inline ในไฟร์เบรคจะใช้ความสามารถของโปรแกรม Oinkmaster ในการอัปเดต Signature ให้ทันสมัย สำหรับการติดตั้งและการใช้งานโปรแกรม Oinkmaster สามารถทำได้เหมือนดังที่กล่าวมาในส่วนการพัฒนาระบบไฟร์สกรีน

สำหรับกฎต่าง ๆ ที่สำคัญในการป้องกันเว็บเซิร์ฟเวอร์ได้แก่ bleeding-web.rules, bleeding-exploit.rules, bleeding-scan.rules, bleeding-attack response.rules ซึ่งสามารถดาวน์โหลดได้ที่ <http://www.bleedingsnort.com/> หลังจากนั้นทำการปรับแต่งค่าต่าง ๆ ในไฟล์ต่อไปนี้

- ปรับแต่งค่าในไฟล์ /etc/oinkmaster.conf ดังนี้

```
url = http://www.bleedingthreats.net/bleeding.rules.tar.gz
modifysid * "^alert" | "drop"
```

url - เป็นส่วนในการกำหนด url ที่ใช้สำหรับดาวน์โหลด Signature

modifysid - เป็นส่วนสำหรับเปลี่ยนแปลงกฎทั้งหมดที่เป็น alert อยู่ ให้กลายเป็น drop

- ปรับแต่งค่าในไฟล์ `/etc/snort_inline/snort_inline.conf` ให้รองรับการทำงานของกฎใหม่ๆ เหล่านี้โดยเพิ่มการตั้งค่าในส่วนของ drop rules ในไฟล์ดังกล่าว ดังนี้

```
include $RULE_PATH/bleeding-web.rules
include $RULE_PATH/bleeding-exploit.rules
include $RULE_PATH/bleeding-scan.rules
include $RULE_PATH/bleeding-attack response.rules
```

8.4 การทำงานของโปรแกรม

สำหรับการทำงานของไฟร์เบรกเป็นดังต่อไปนี้ คือเมื่อทำการตั้งค่าและเปิดบริการของ Squid และ snort-inline แล้ว เครื่องไฟร์เบรกจะอยู่ในสถานะ Listening รอรับการเชื่อมต่อจากไคลเอนต์ที่ต้องการใช้บริการเว็บเซิร์ฟเวอร์ที่อยู่หลังไฟร์เบรก โดยไฟร์เบรกจะรอรับแพ็คเก็ตที่มาจากไคลเอนต์แล้วทำการตรวจสอบแพ็คเก็ตนั้นกับกฎที่มีอยู่ว่าเข้าข่ายพฤติกรรมเป็นผู้บุกรุกหรือไม่ ถ้าแพ็คเก็ตนั้นตรงตามกฎของ snort-inline แสดงว่าเข้าข่ายเป็นผู้บุกรุก ไฟร์เบรกจะทำการดริอปแพ็คเก็ตนั้นทิ้งและทำการส่งล็อกไฟล์ที่เกี่ยวกับการบุกรุกนั้น ๆ ไปยังโปรแกรมควบคุม Tartarus Management แต่ถ้าแพ็คเก็ตนั้นเป็นแพ็คเก็ตปกติ ไฟร์เบรกจะอนุญาตให้ไคลเอนต์สามารถติดต่อกับเว็บเซิร์ฟเวอร์เพื่อรับบริการจากเว็บเซิร์ฟเวอร์ได้ตามปกติ